

ТЕХНИЧЕСКОЕ ОПИСАНИЕ СИСТЕМЫ

Назначение, возможности, устройство и защита информации

Аудитория: руководители подразделений, специалисты по информационным технологиям, специалисты по защите информации

Версия документа: 1.0

Дата: 28.07.2026

СОДЕРЖАНИЕ

1. Общие сведения.....	4
1.1. Назначение документа.....	4
1.2. Состав документации.....	4
1.3. Область применения.....	4
1.4. Оформление.....	5
2. Термины и сокращения.....	5
3. Назначение системы.....	6
3.1. Решаемые задачи.....	6
3.2. Границы применения.....	7
4. Пользователи системы.....	7
4.1. Типы учётных записей.....	7
4.2. Разграничение доступа.....	8
5. Жизненный цикл заявки.....	9
5.1. Порядок обработки.....	9
5.2. Проверка по чёрным спискам.....	10
5.2. Прозрачность обработки.....	10
6. Функциональные возможности.....	11
7. Поиск и работа с накопленными данными.....	12
7.1. Поиск, устойчивый к способу ввода.....	12
7.2. Приведение сведений к единому виду.....	12
7.3. Повторное использование ранее заведённых сведений.....	13
7.4. Скорость поиска при накоплении данных.....	13
8. Обучение работе с системой.....	13
8.1. Обучающий тур.....	13
8.2. Встроенное руководство.....	14
8.3. Сообщение о сбое.....	14
9. Устройство системы.....	14
9.1. Состав частей.....	14
9.2. Технологическая основа.....	16
9.3. Фоновые задачи.....	16
10. Организация данных.....	16

10.1. Состав базы данных.....	16
10.2. Сохранность исторических сведений.....	17
10.3. Поиск по большим объёмам.....	17
11. Программный интерфейс.....	17
12. Обновление данных без перезагрузки.....	18
13. Защита информации.....	19
13.1. Проверка подлинности.....	19
13.2. Разграничение доступа.....	19
13.3. Защита передаваемых данных.....	20
13.4. Защита от типовых атак.....	20
13.5. Защита персональных данных при хранении.....	20
13.6. Учёт обращений к персональным данным.....	21
13.7. Согласия на обработку персональных данных.....	21
13.8. Журналы и прослеживаемость.....	22
13.9. Автоматический контроль защищённости.....	22
14. Тестирование и обеспечение качества.....	23
14.1. Уровни тестирования.....	23
14.2. Что дают тесты при сопровождении.....	24
14.3. Автоматический конвейер сборки и проверки.....	24
14.4. Проверочный стенд.....	25
15. Масштаб системы.....	25
Приложение А. Категории прав доступа.....	26

1. Общие сведения

1.1. Назначение документа

Документ описывает систему электронной подачи заявок «Бюро пропусков»: какие задачи она решает, как устроена работа пользователей, из каких частей состоит и какими средствами защищены обрабатываемые в ней сведения.

Документ предназначен для знакомства с системой перед вводом в эксплуатацию и для понимания её устройства в целом. Порядок установки и сопровождения вынесен в отдельный документ, «Руководство по развёртыванию и сопровождению».

1.2. Состав документации

Таблица 1.1 — Состав эксплуатационной документации

Документ	Кому адресован	Содержание
Техническое описание системы	Руководители, специалисты ИТ и защиты информации	Настоящий документ: назначение, возможности, устройство, защита информации
Руководство по развёртыванию и сопровождению	Подразделение информационных технологий	Требования, установка, настройка, эксплуатация, диагностика
Руководство пользователя	Заявитель	Подача заявок, работа с личным кабинетом
Руководство администратора	Сотрудник бюро пропусков с правами администратора	Пользователи, права, справочники, таблицы постов, аудит
Руководство охранника	Сотрудник поста	Работа с таблицами поста, отметка прохода, проверка пропуска

Описание программного интерфейса формируется автоматически из исходного кода и доступно в работающей системе.

1.3. Область применения

Система предназначена для организации пропускного режима на территории предприятия: оформления, согласования и учёта заявок на проход людей, проезд транспорта, внос и вынос материальных ценностей, а

также для контроля фактического нахождения людей и транспорта на территории.

1.4. Оформление

Команды, имена файлов и параметры набраны моноширинным шрифтом. Таблицы, рисунки и примеры команд нумеруются по разделам. Угловые скобки означают подстановку: <домен> заменяется фактическим значением без скобок.

Отдельно выделяются сведения, требующие повышенного внимания:

ПРИМЕЧАНИЕ. Так оформляются пояснения, которые полезно знать, но которые не влияют на порядок действий.

ВАЖНО. Так оформляются сведения, пропуск которых приведёт к неверной работе или к лишней работе по исправлению.

ОПАСНО. Так оформляются действия, последствия которых необратимы: утрата данных или утрата доступа к ним.

2. Термины и сокращения

Таблица 2.1 — Термины, применяемые в документе

Термин	Значение
Заявка	Электронный документ на доступ на территорию: кто проходит, что проезжает, что вносится, на какой срок и куда
Вложение	Часть заявки, объединяющая однородные объекты: людей, транспорт либо материальные ценности. В одной заявке их может быть несколько, с разными сроками и местами
Бланк	Печатная форма по заявке, заполняемая системой по загруженному шаблону электронной таблицы
Пост, проходная	Точка контроля доступа, за которой закреплены перечни допущенных объектов
Таблица поста	Настраиваемый перечень допущенных людей либо транспорта, с которым работает охрана
Место разгрузки	Площадка, к которой привязывается вложение заявки на внос или ввоз ценностей
Чёрный список	Перечень людей и транспорта, которым доступ запрещён
Территориальный статус	Признак нахождения человека или транспорта на территории, изменяется отметками въезда и выезда
Согласующий	Работник, чьё решение требуется для одобрения заявки

Продолжение таблицы 2.1

Термин	Значение
Принимающий	Работник бюро, принявший заявку в работу и отвечающий за её обработку
Супер-администратор	Единственная учётная запись с полным доступом, включая режим технических работ
Персональные данные	Сведения о людях: фамилия, имя, отчество, документ, удостоверяющий личность, гражданство
Маркер доступа	Электронный пропуск в саму систему: короткая строка, которую браузер прикладывает к каждому обращению вместо повторного ввода пароля. Действует 15 минут, затем продлевается автоматически
Сертификат	Электронный документ, которым сервер подтверждает браузеру свою подлинность. Обеспечивает работу по защищённому соединению, тот самый «замок» в адресной строке
Поток событий	Механизм, которым сервер сообщает открытым страницам об изменениях, чтобы данные обновлялись без нажатия кнопки обновления

3. Назначение системы

3.1. Решаемые задачи

Система предназначена для ведения пропускного режима в электронном виде: оформления заявок на доступ, их согласования, учёта фактического прохода и хранения связанных сведений.

Таблица 3.1 — Задачи, решаемые системой

Задача	Как решается
Передача заявки между участниками	Заявка доступна бюро сразу после отправки. Согласующие работают с ней в системе, передавать документ физически не требуется
Отслеживание состояния заявки	Заявитель видит текущий статус и историю изменений, не обращаясь к бюро
Сохранность сведений	Данные хранятся в базе. Записи справочников не удаляются, а переводятся в архив, поэтому заявки прошлых периодов остаются читаемыми
Поиск по накопленным данным	Поиск по части слова, с учётом раскладки клавиатуры и латинского написания. Подробнее в разделе 7
Единая картина по всем постам	Посты работают с общими данными. Отметка о въезде видна остальным без задержки
Учёт обращений к персональным данным	Каждое обращение записывается в отдельный журнал. Подробнее в подразделе 13.6

Продолжение таблицы 3.1

Задача	Как решается
Контроль запретов на доступ	Объекты заявки сверяются с чёрными списками при подаче, в том числе с учётом подмены символов. Подробнее в подразделе 5.2

3.2. Границы применения

Система обеспечивает оформление, согласование и учёт доступа. Она не управляет исполнительными устройствами: шлагбаумами, турникетами и замками. Отметка о проходе вносится работником поста.

4. Пользователи системы

4.1. Типы учётных записей

В системе заведено шесть типов учётных записей. Тип носит справочный характер и служит для классификации работников. Он не определяет, что работник может делать: объём полномочий задаётся ролями и группами прав, поэтому два работника одного типа могут иметь разный доступ, а работники разных типов - одинаковый.

Таблица 4.1 — Типы учётных записей

Тип
Пользователь
Арендатор
Подрядчик
Охранник
Руководитель
Бюро пропусков

Типы создаются и редактируются администратором, перечень не является закрытым.

ПРИМЕЧАНИЕ. Настройку системы через интерфейс (справочники, таблицы постов, права, учётные записи) ведут сотрудники бюро пропусков под учётной записью с соответствующими правами. Порядок этих действий описан в руководстве администратора.

4.2. Разграничение доступа

Права вычисляются по четырёхуровневой модели. Уровни рассматриваются по порядку, первый подходящий определяет результат.

1. Заблокированный работник не имеет прав вообще, независимо от назначенных ролей.
2. Супер-администратор имеет полный доступ, включая режим технических работ и назначение прав администратора. Такая учётная запись в системе одна, это ограничение поддерживается принудительно.
3. Администратор имеет полный доступ, кроме действий супер-администратора и кроме персональных запретов.
4. Обычный работник получает права из назначенной роли, групп прав этой роли и персонально назначенных групп. Затем применяются персональные исключения, причём запрет имеет приоритет над разрешением.

Приоритет запрета позволяет закрыть конкретному работнику отдельное действие, не разрушая назначенную ему роль и не создавая роль на одного человека.

Каталог прав содержит 49 фиксированных ключей в семи категориях. Дополнительно на каждую созданную таблицу поста автоматически создаётся девять прав: просмотр, отметка въезда, отметка выезда, карточка объекта, история, версии, выгрузка, корзина, удаление. Заводить права для новой таблицы вручную не требуется.

Отказы в доступе записываются в журнал: работник, запрошенное действие, время. Это позволяет отличить неверно настроенные права от попытки обойти ограничения.

5. Жизненный цикл заявки

5.1. Порядок обработки

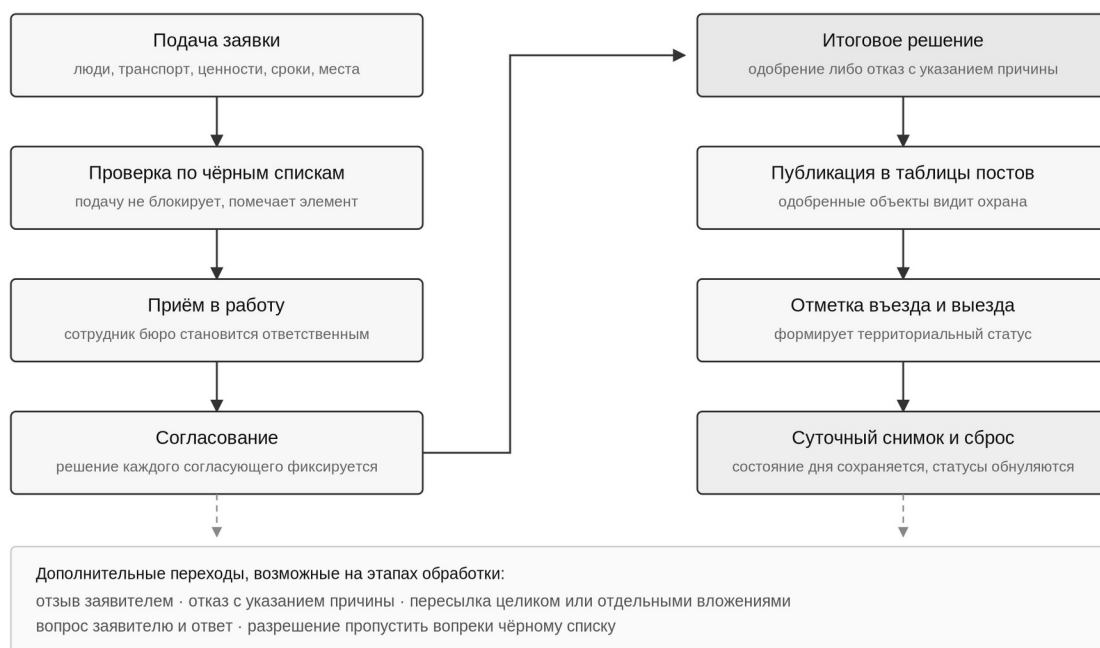


Рисунок 5.1 — Порядок прохождения заявки

Заявитель заполняет заявку: указывает организацию, добавляет вложения по людям, транспорту и ценностям, задаёт сроки и места, при необходимости прикладывает файлы, подтверждает согласие на обработку персональных данных и отправляет.

При отправке объекты заявки сверяются с чёрными списками. Порядок сверки описан в подразделе 5.2.

Заявка попадает в центр заявок. Сотрудник бюро принимает её в работу и становится ответственным. При необходимости назначаются согласующие, решение каждого фиксируется отдельно. Обработчик может задать заявителю вопрос и получить ответ, не выходя из карточки заявки, а также переслать заявку целиком или отдельными вложениями в другое подразделение.

После завершения обработки одобренные объекты попадают в таблицы соответствующих постов и становятся видны охране. Работник поста

отмечает фактический въезд и выезд, эти отметки формируют территориальный статус и историю проходов.

Ежесуточно в заданное время система сохраняет снимок состояния таблиц и обнуляет территориальные статусы, чтобы новый день начинался с чистого листа, а состояние предыдущего оставалось доступным для разбора.

5.2. Проверка по чёрным спискам

Сверка выполняется при отправке заявки и работает на двух уровнях.

Точное совпадение. Если объект заявки совпадает с действующей записью чёрного списка, заявка не принимается, а заявитель получает отказ с пояснением.

Близкое совпадение. Сравнение выполняется не по исходной строке, а по приведённой к единому виду, поэтому обнаруживаются варианты, которыми точное сравнение обойти легко: подмена русских букв внешне похожими латинскими, замена буквы «О» на ноль в номере, опечатка, отсутствие отчества. Такой объект помечается признаком возможного совпадения с указанием, с какой записью и насколько близко он совпал.

Пометка не блокирует подачу, но **блокирует согласование заявки** до тех пор, пока по каждому помеченному объекту не будет принято явное решение пропустить его вопреки запрету. Такое решение фиксируется отдельной записью с указанием принявшего его работника, поэтому ответственность за пропуск персонализирована.

Повторные предупреждения по той же паре «объект и запись чёрного списка» после принятого решения не выводятся.

5.2. Прозрачность обработки

Заявитель в любой момент видит текущее состояние заявки и историю её изменений: когда принята в работу, кто ответственный, какие решения приняли согласующие, по какой причине отказано. Обращаться за этими сведениями к бюро не требуется.

Отметки прочтения ведутся персонально: система различает, кто именно из имеющих доступ работников открывал заявку, а не только факт открытия.

6. Функциональные возможности

Таблица 6.1 — Функциональные подсистемы

Подсистема	Возможности
Заявки	Создание, приём в работу, согласование, завершение, отказ, отзыв. Пересылка целиком и по вложениям, вопросы и ответы, история статусов, персональные отметки прочтения
Вложения и бланки	Группировка объектов внутри заявки, настраиваемые дополнительные поля, шаблоны печатных форм с привязкой к ячейкам таблицы, формирование заполненного бланка
Транспорт	Реестр транспортных средств, привязка к заявкам и постам, отметки въезда и выезда, история проездов, добавление вне заявки
Люди	Реестр физических лиц, документы, гражданство, история проходов, прикрепление файлов
Чёрные списки	Раздельные перечни по людям и транспорту, проверка при подаче, признак возможного совпадения, разрешение пропуска вопреки запрету с фиксацией
Таблицы постов	Конструктор перечней: настраиваемые столбцы, фотографии, временные интервалы, корзина удалённых записей, суточные снимки, выгрузка
Места разгрузки	Справочник площадок, фотографии, расписания, привязка к организациям
Организации и компании	Структура арендаторов и подрядчиков, ответственные лица, привязка ресурсов, групповые операции
Аналитика и отчёты	Панель показателей, конструктор отчётов, сохраняемые шаблоны, сводные таблицы, выгрузка в электронную таблицу
Права доступа	Роли, группы прав, персональные исключения, журнал отказов
Учётные записи	Заведение, блокировка, журнал входов, групповые операции
Новости и объявления	Публикации с форматированным текстом и изображениями, объявление-баннер на главной
Уведомления	Уведомления о событиях по заявкам, доставляются без обновления страницы
Справочники	Гражданства, марки транспорта, форматы регистрационных знаков, типы вложений, типы работников, документы, режим работы бюро
Обратная связь	Обращения работников со статусами, отправка сообщения о сбое
Обучение	Встроенное руководство по ролям и обучающий тур по интерфейсу. Подробнее в разделе 8
Журналы и режим работ	Журнал запросов, сводный журнал изменений, журнал обращений к персональным данным, режим технических работ

7. Поиск и работа с накопленными данными

7.1. Поиск, устойчивый к способу ввода

Поиск рассчитан на быстрый и неаккуратный ввод. По введённой строке система строит несколько вариантов запроса и ищет по каждому.

Таблица 7.1 — Что распознаёт поиск

Ситуация	Пример ввода	Что будет найдено
Часть слова, в том числе из середины	иван	Иванов, Иваненко, Селиванов
Ввод в неверной раскладке клавиатуры	bdfyjd	Иванов
Латинское написание вместо русского	ivanov	Иванов
Различие в регистре	ИВАНОВ	Иванов
Номер слитно и раздельно	a123bc и a 123 bc	A123BC

Поиск работает по фамилиям, именам и отчествам, номерам заявок, государственным регистрационным знакам, маркам транспорта, наименованиям организаций и мест разгрузки, тексту сопроводительных писем и комментариев.

Одинаковые правила действуют и на сервере, и в списках, которые фильтруются в браузере, поэтому поведение поиска не зависит от раздела.

ПРИМЕЧАНИЕ. Поиск с исправлением опечаток применяется отдельно, при сверке с чёрными списками (подраздел 5.2). В обычном поиске опечатка в середине слова результата не даст, поскольку поиск ведётся по фрагменту введённой строки.

7.2. Приведение сведений к единому виду

Часть сведений приводится к единой форме автоматически, чтобы одинаковые по смыслу записи не расходились в написании.

- Государственные регистрационные знаки: убираются пробелы и разделители, латинские буквы, внешне совпадающие с русскими, заменяются на русские, ноль и буква «О» приводятся к одному виду.
- Фамилии, имена и отчества: убираются лишние пробелы, приводится регистр, «е» и «ё» считаются одной буквой.

- Наименования организаций: приводится к единому виду организационно-правовая форма и кавычки. Применяется при разборе организаций, поступающих с заявками, и при модерации справочника.

Приведённая форма используется при сверке с чёрными списками и хранится рядом с исходной, поэтому исходное написание не теряется.

7.3. Повторное использование ранее заведённых сведений

Сотрудники и транспортные средства, ранее заводившиеся в системе, хранятся в реестрах. При оформлении заявки их не требуется вводить заново: в форме предусмотрен выбор из реестра.

По кнопке открывается окно со списком ранее заведённых записей, в котором есть собственный поиск и возможность отметить сразу несколько записей. Отмеченные записи добавляются в заявку вместе с ранее указанными сведениями.

7.4. Скорость поиска при накоплении данных

Для полей, по которым ведётся поиск, создано 17 специальных индексов. Они позволяют искать по фрагменту слова, не перебирая таблицу целиком, поэтому скорость поиска не падает по мере накопления данных.

8. Обучение работе с системой

Система рассчитана на работников без специальной подготовки, поэтому обучение встроено в интерфейс.

8.1. Обучающий тур

При первом входе запускается пошаговый тур: система последовательно подсвечивает элементы интерфейса и объясняет их назначение. Тур учитывает роль работника, для поста показываются шаги по таблицы и отметки прохода.

Тур можно пройти повторно в любой момент. Администратор может сбросить отметку о прохождении конкретному работнику, например при переводе на другую должность.

Тур версионизируется: после существенного изменения интерфейса работникам показываются новые шаги, а не пройденный ранее старый вариант.

8.2. Встроенное руководство

В системе есть раздел справки с отдельными материалами для заявителя, охранника и администратора. Материал раздела состоит из вводного текста, перечня пунктов и прикрепленного файла. Всё это ведётся администратором в самой системе, поэтому обновление справки не требует выпуска новой версии программы.

8.3. Сообщение о сбое

Если работник столкнулся с ошибкой, он может отправить сообщение прямо из системы. Сообщение сохраняется вместе со сведениями о том, что происходило в момент сбоя, и попадает в раздел обратной связи, где обрабатывается со статусами.

9. Устройство системы

9.1. Состав частей

Система собрана из отдельных частей, каждая работает в собственном контейнере. Наружу открыта одна из них, обратный прокси. Остальные работают во внутренней сети сервера и с рабочих мест недоступны.

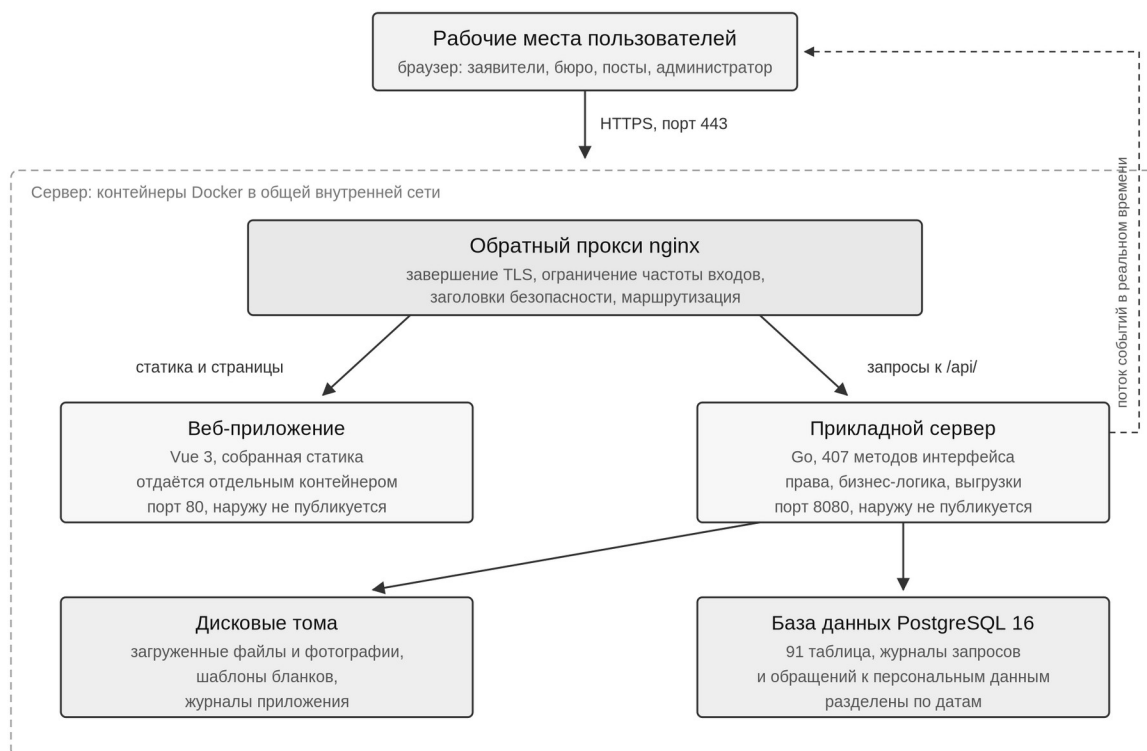


Рисунок 9.1 — Состав системы и потоки данных

Обратный прокси принимает защищённое соединение, расшифровывает его и распределяет запросы: обращения к данным уходят на прикладной сервер, всё остальное отдаёт веб-приложение. Прикладной сервер обращается к базе данных и к хранилищу файлов. Обратный поток событий идёт от прикладного сервера прямо в браузер и обновляет открытые страницы.

Таблица 9.1 — Части системы

Часть	Основа	Роль
Обратный прокси	nginx	Защищённое соединение, ограничение частоты попыток входа, заголовки безопасности, распределение запросов
Веб-приложение	Vue 3	Интерфейс, с которым работает пользователь в браузере
Прикладной сервер	Go	Проверка прав, обработка заявок, работа с данными, формирование выгрузок
База данных	PostgreSQL 16	Хранение всех сведений системы

9.2. Технологическая основа

Таблица 9.2 — Применённые технологии

Уровень	Технологии
Прикладной сервер	Go 1.25, веб-каркас Echo, работа с базой через GORM и драйвер pgx, формирование электронных таблиц и печатных форм
Веб-приложение	Vue 3.5, хранилище состояния Pinia, сборка Vite, построение диаграмм, редактор форматированного текста
Хранение	PostgreSQL 16 с разделением журнальных таблиц по датам и поиском по фрагментам слов
Развёртывание	Docker и Docker Compose, работа от непривилегированного пользователя

9.3. Фоновые задачи

Прикладной сервер сам выполняет периодические задачи, отдельный планировщик в операционной системе не нужен.

Таблица 9.3 — Периодические задачи

Задача	Периодичность	Действие
Архивация просроченных вложений	15 минут	Вложения с истёкшим сроком перестают действовать
Архивация журнала отказов	Сутки	Записи старше 90 суток переносятся в архив
Суточный снимок и сброс	Ежесуточно в 06:00	Сохраняется состояние таблиц постов, территориальные статусы обнуляются
Фиксация пика посещаемости	Минута	Записывается наибольшее число одновременно работающих за сутки
Пересчёт показателей аналитики	60 секунд	Панель открывается сразу, без ожидания расчёта
Обслуживание журнальных таблиц	Сутки	Создание разделов вперёд, свёртка и удаление устаревших

10. Организация данных

10.1. Состав базы данных

База содержит 96 таблиц: справочники, учётные записи и права, заявки со связанными сущностями, реестры людей и транспорта, таблицы постов, журналы.

Две журнальные таблицы растут быстрее прочих, поэтому физически разделены по датам. Это позволяет удалять устаревшие сведения мгновенно, отбрасывая целый раздел, вместо построчного удаления, которое на больших объёмах занимало бы часы.

Таблица 10.1 — Разделение журнальных таблиц

Журнал	Разделение	Срок хранения
Журнал запросов	По суткам	Подробные записи 30 суток, далее суточные итоги
Журнал обращений к персональным данным	По месяцам	36 месяцев без свёртки

10.2. Сохранность исторических сведений

Записи справочников не удаляются физически, а переводятся в архив. Заявка прошлого года, ссылающаяся на упразднённое место разгрузки или снятую с учёта марку, остаётся полностью читаемой. Архивная запись не предлагается при заполнении новых заявок и помечается в старых.

Удалённые строки таблиц постов попадают в корзину, откуда их можно восстановить.

10.3. Поиск по большим объёмам

Для поиска по фамилиям, номерам заявок, регистрационным знакам и наименованиям организаций создано 17 специальных индексов. Они позволяют искать по фрагменту слова и с опечатками, не перебирая таблицу целиком, поэтому скорость поиска не падает по мере накопления данных.

11. Программный интерфейс

Обмен данными между браузером и сервером идёт через программный интерфейс. Он же может использоваться для интеграции с другими системами предприятия.

Зарегистрировано 459 методов в 37 группах. Ответ всегда имеет одинаковую структуру, что упрощает разбор при интеграции.

```
{
  "success": true,
  "data":    { ... },
  "meta":    { "page": 1, "limit": 20, "total": 137 },
  "error":   ""
}
```

Поле `meta` присутствует у методов, возвращающих постраничные списки: оно сообщает номер страницы, её размер и общее число записей. При ошибке поле `success` принимает значение `false`, а пояснение помещается в `error`.

Без входа в систему отвечают только шесть методов: вход, продление сеанса, перечень типов работников, признак режима технических работ, контактные сведения и поток событий. Все остальные требуют действующего маркера доступа и проходят проверку прав.

Описание интерфейса формируется из исходного кода при сборке, поэтому не расходится с фактической реализацией.

12. Обновление данных без перезагрузки

Открытые страницы обновляются сами: новая заявка появляется в центре заявок, отметка о въезде видна другим постам, счётчик непрочитанного меняется без нажатия кнопки обновления.

Применена схема, при которой сервер сообщает только то, какую область следует обновить, но не передаёт сами сведения. Получив сигнал, браузер выполняет обычный запрос, к которому применяются права конкретного работника. Благодаря этому по каналу обновлений невозможно узнать ничего сверх собственных полномочий: он не переносит данные.

Подключение к потоку событий авторизуется одноразовым билетом, а само соединение принудительно обновляется каждые 10 минут. При обновлении повторно проверяются права и блокировка учётной записи, поэтому отзыв доступа вступает в силу не позднее чем через 10 минут даже у работника с открытой страницей.

13. Защита информации

13.1. Проверка подлинности

Таблица 13.1 — Механизмы проверки подлинности

Механизм	Реализация
Хранение паролей	Алгоритм Argon2id, устойчивый к подбору на видеокартах. Пароли в открытом виде не хранятся и не попадают в журналы
Маркер доступа	Действует 15 минут, подписан отдельным ключом
Продление сеанса	Отдельный маркер сроком 7 суток, передаётся только по защищённому соединению
Одноразовость продления	Использованный маркер продления сразу становится недействительным
Обнаружение кражи сеанса	Повторное предъявление уже использованного маркера аннулирует всю цепочку сеансов работника
Завершение всех сеансов	Администратор может отозвать доступ работника немедленно
Защита от подбора	Блокировка учётной записи после серии неудачных попыток и ограничение частоты попыток с одного адреса

Обнаружение кражи сеанса работает так: если маркер продления похищен и использован посторонним, законный работник при следующем продлении предъявит уже использованный маркер. Система расценит это как признак компрометации и прекратит оба сеанса, а событие останется в журнале.

13.2. Разграничение доступа

Модель прав описана в подразделе 4.2. С точки зрения защиты информации существенны три её свойства.

Проверка выполняется на сервере при каждом обращении. Скрытие кнопки или пункта меню в интерфейсе рассматривается как удобство, а не как мера защиты: работник, обратившийся к системе в обход интерфейса, получит отказ на общих основаниях.

Права вычисляются по принципу «запрещено всё, что не разрешено». Отсутствие явного разрешения означает отказ.

Каждый отказ фиксируется в журнале с указанием работника, запрошенного действия и времени.

13.3. Защита передаваемых данных

Соединение защищается протоколами TLS 1.2 и 1.3, устаревшие версии и слабые алгоритмы отключены. Обращения по незащищённому протоколу перенаправляются на защищённый.

Дополнительно передаются заголовки, ограничивающие поведение браузера: обязательное использование защищённого соединения, запрет встраивания страниц системы в чужие сайты, запрет угадывания типа содержимого, ограничение источников загружаемых ресурсов, запрет доступа к камере, микрофону и определению местоположения.

13.4. Защита от типовых атак

Таблица 13.2 — Меры против типовых атак

Угроза	Мера защиты
Внедрение команд в запрос к базе данных	Все запросы к базе параметризованы. В конструкторе отчётов имена полей подставляются только из фиксированного перечня, заданного в коде, а не из введённого пользователем текста
Выполнение чужого сценария в браузере	Форматированный текст очищается перед выводом по перечню разрешённых элементов, встроенные сценарии и обработчики событий удаляются
Обращение к чужим данным по идентификатору	Принадлежность проверяется на сервере. Перечень заявок обычному работнику возвращает только его собственные
Действия в обход интерфейса	Права проверяются на сервере при каждом обращении
Загрузка вредоносного файла	Тип определяется по содержимому файла, а не по расширению, поэтому переименование не помогает. Размер ограничен, имя файла на диске заменяется на служебное
Подбор пароля	Ограничение частоты попыток и блокировка учётной записи
Избыточная нагрузка запросами	Ограничение числа запросов на работника и отдельное, более строгое, ограничение попыток входа
Обход чёрного списка подменой букв	Записи и запросы приводятся к единому виду перед сравнением, подмена русских букв латинскими не срабатывает

13.5. Защита персональных данных при хранении

Сведения документов, удостоверяющих личность, хранятся в базе в зашифрованном виде. Применён алгоритм AES-256 в режиме, который обеспечивает одновременно скрытие содержимого и защиту от подмены.

Шифрование выполняется автоматически при записи и расшифровка при чтении, поэтому записать такие сведения в открытом виде в обход шифрования нельзя.

Поиск по зашифрованным полям решён отдельно: рядом с зашифрованным значением хранится необратимая свёртка, вычисленная с секретным ключом. Поиск ведётся по ней, что позволяет находить запись, не расшифровывая всю таблицу и не раскрывая содержимое.

ОПАСНО. Ключ шифрования является единственным способом прочитать эти сведения. При его утрате данные не восстанавливаются ни из резервной копии базы, ни средствами разработчика: копия содержит те же зашифрованные значения. Порядок хранения ключа описан в руководстве по развёртыванию и сопровождению.

13.6. Учёт обращений к персональным данным

Ведётся отдельный журнал обращений к сведениям о людях. Записываются работник, характер действия (просмотр, создание, изменение, удаление), затронутый раздел, сетевой адрес, время и результат.

Журнал доступен администратору в разделе администрирования системы, с фильтрами по работнику, действию и периоду. Открывается он по отдельному праву, то есть доступ к самому журналу тоже разграничен.

Записи хранятся 36 месяцев и не удаляются вместе с обычным журналом запросов. Запись выполняется в фоне и не замедляет работу пользователя, при этом сведения о запросе снимаются до передачи в фоновую задачу, что исключает их искажение.

13.7. Согласия на обработку персональных данных

При подаче заявки заявитель подтверждает согласие на обработку персональных данных. Фиксируется факт согласия, его вид, сетевой адрес и сведения о браузере в момент подтверждения, а также время. Отзыв согласия поддерживается и также фиксируется временем.

Документ об обработке персональных данных публикуется администратором в системе и доступен на странице подачи заявки.

13.8. Журналы и прослеживаемость

Таблица 13.3 — Журналы системы

Журнал	Что фиксирует	Кому доступен
Журнал запросов	Все обращения к системе: работник, действие, результат, длительность	Администратору и работникам с правом просмотра
Журнал обращений к персональным данным	Обращения к сведениям о людях	По отдельному праву
Журнал изменений	Кто, когда и что изменил в сущностях системы	Администратору
Журнал отказов в доступе	Попытки выполнить действие без прав	Администратору
Журнал входов	Входы, выходы, неудачные попытки, блокировки	Администратору

Совокупность журналов позволяет восстановить картину по любому вопросу вида «кто это сделал и когда».

13.9. Автоматический контроль защищённости

Поиск уязвимостей встроен в конвейер сборки и выполняется при каждом изменении программы, а также еженедельно по расписанию, когда сама программа не менялась. Последнее важно: сведения об уязвимости часто появляются уже после выпуска версии.

Таблица 13.4 — Средства автоматического поиска уязвимостей

Средство	Что проверяет	Поведение при обнаружении
govulncheck	Библиотеки серверной части на уязвимости из базы уязвимостей Go. Учитывает, вызывается ли уязвимый код фактически, что отсеивает ложные срабатывания	Сборка прерывается
npm audit	Библиотеки интерфейса, участвующие в сборке	Сборка прерывается при уровне «высокий» и выше
Trivy	Собранный образ контейнера целиком: системные пакеты операционной системы и библиотеки внутри образа	Сборка прерывается при уровне «критический» и «высокий»

Прерывание сборки означает, что версия с известной уязвимостью не может быть выпущена: её невозможно собрать и выложить, пока уязвимость не устранена.

Обновления библиотек предлагаются автоматически, сгруппированные по назначению, и проходят полный набор тестов до применения. Благодаря этому зависимости не устаревают незаметно.

Дополнительно проведён аудит разграничения доступа по методике проверки функциональной авторизации: последовательно проверялось, что каждое действие недоступно работнику без соответствующего права. Выявленные несоответствия устранены. Чтобы они не появились вновь при развитии системы, добавлены автоматические проверки, закрепляющие требуемое разграничение: попытка выпустить версию, в которой действие открыто без права, будет остановлена на этапе проверок.

14. Тестирование и обеспечение качества

14.1. Уровни тестирования

Качество обеспечивается тремя уровнями автоматических тестов. Каждый уровень ловит свой класс ошибок, и ни один не заменяет остальные.

Таблица 14.1 — Состав автоматических тестов

Уровень	Инструмент	Объём	Что покрывает
Бэкенд-тесты, модульные и интеграционные	Штатное средство тестирования Go	1 229 тестов в 206 файлах	Обработку заявок, разграничение доступа, работу с данными, выгрузки, шифрование
Фронтенд-тесты	Vitest	2 670 тестов в 310 файлах	Поведение экранов и элементов, обработку данных на стороне браузера, хранилища состояния
E2E-сценарии, сквозные	Playwright	159 тестов в 42 файлах	Работу системы целиком в браузере от входа до результата, а также прямые обращения к программному интерфейсу
Всего		4 058	

Существенная особенность: 157 файлов бэкенд-тестов выполняются **на настоящей базе данных**, которая разворачивается специально для прогона, а не на её упрощённой замене. Это медленнее, но обнаруживает ошибки в запросах, ограничениях целостности и правах, которые упрощённая замена пропустила бы в принципе.

E2E-сценарии запускаются в настоящем браузере и повторяют действия работника: заполнение формы заявки, приём в работу, отметку въезда на посту, открытие разделов администрирования.

Отдельно поддерживаются тесты, закрепляющие разграничение доступа: они пытаются выполнить действие без права и требуют получить отказ. Такие тесты не дают случайно открыть доступ при доработках.

14.2. Что дают тесты при сопровождении

Набор тестов нужен не сам по себе, а как страховка при внесении изменений. Практический эффект такой.

- Ошибка обнаруживается до выкладывания, а не пользователем на рабочем сервере.
- Доработка одной части системы, случайно сломавшая другую, будет остановлена: E2E-сценарии проходят по основным рабочим процессам целиком.
- Разграничение доступа защищено от случайного ослабления.
- Известные уязвимости в используемых библиотеках обнаруживаются автоматически, включая появившиеся уже после выпуска версии.

14.3. Автоматический конвейер сборки и проверки

Конвейер построен на GitHub Actions и запускается сам при каждом изменении программы. Ручного запуска проверок не требуется.

Таблица 14.2 — Состав конвейера

Этап	Что выполняется
Определение изменений	Анализируется, какие части затронуты, чтобы не запускать лишнее и не тратить время

Изменение, не прошедшее хотя бы один этап, к выпуску не допускается.

Дополнительно раз в неделю по расписанию выполняется полный прогон сканирования уязвимостей. Это нужно, чтобы обнаружить уязвимости, о которых стало известно уже после выпуска версии, когда сама программа не менялась.

Обновления используемых библиотек предлагаются автоматически, сгруппированные по назначению, и проходят полный набор тестов до применения. Благодаря этому система не накапливает устаревшие зависимости.

14.4. Проверочный стенд

Помимо рабочего сервера поддерживается отдельный стенд с той же системой. Изменения попадают на него автоматически после успешного прохождения проверок, что позволяет посмотреть их вживую до выкладывания на рабочий сервер.

Стенд закрыт запросом имени и пароля на входе и содержит отдельную базу, поэтому эксперименты на нём не затрагивают рабочие данные.

Порядок работы со стендом и порядок выкладывания на рабочий сервер описаны в руководстве по развёртыванию и сопровождению.

15. Масштаб системы

Сведения приводятся для оценки объёма разработки и трудоёмкости сопровождения.

Таблица 15.1 — Количественные показатели

Показатель	Значение
Объём исходного кода	346 875 строк в 1 223 файлах
Серверная часть	64 263 строки: 123 службы, 61 обработчик, 70 моделей данных
Интерфейс	175 920 строк: 36 экранов, 194 элемента интерфейса
Методы программного интерфейса	459 в 37 группах
Таблицы базы данных	96

Продолжение таблицы 15.1

Показатель	Значение
Автоматические тесты	4 058
Расчётная нагрузка	1000-1500 одновременно работающих пользователей

Приложение А. Категории прав доступа

Таблица А.1 — Категории прав

Категория	Содержание
Разделы навигации	Доступ к экранам системы
Элементы верхней панели	Действия, доступные из шапки
Центр заявок	Просмотр и обработка заявок, приём в работу, решения
Карточки объектов	Просмотр карточек транспорта и людей, история
Реестры	Работа с реестрами людей и транспорта
Администрирование	Учётные записи, права, справочники, журналы
Обзор и руководство	Доступ к разделам встроенной справки
Таблицы постов	Создаются автоматически для каждой таблицы: просмотр, отметки въезда и выезда, карточка, история, версии, выгрузка, корзина, удаление

Два действия доступны исключительно супер-администратору: включение режима технических работ и назначение прав администратора.